

Informe de Auditoría de Seguridad Cruzada (DevSecOps - IA)

Fecha de Entrega: 31/08/2026

Auditor: Guido Ygounet

Proyecto Auditado: [fork:Diplo-2026-DevSecOps-David-IA](#) - [Repositorio Original](#)

1. Vulnerabilidades Encontradas (OWASP Top 10 y Riesgos en IA)

Basado en el análisis estático del código fuente proporcionado, se identificaron los siguientes puntos:

- **Riesgos de IA - LLM01 (Prompt Injection):** La mitigación actual contra la inyección de prompts se basa en expresiones regulares definidas en `OVERRIDE_PATTERNS` que buscan frases como "ignore", "disregard" o "revela". Este enfoque es altamente susceptible a evasiones semánticas, traducciones no contempladas u ofuscación, permitiendo que un atacante altere el comportamiento del modelo.
- **OWASP Top 10 - A04:2021 (Insecure Design) / Denegación de Servicio (DoS):** La aplicación implementa limitación de tasa a través de la clase `InMemoryRateLimiter`, la cual utiliza memoria local y bloqueos de hilos (`Lock`). En un entorno de despliegue distribuido con múltiples réplicas (pods/contenedores), este estado no se comparte, lo que permitiría a un atacante eludir el límite de solicitudes distribuyendo el tráfico entre distintas instancias.
- **OWASP Top 10 - A07:2021 (Identification and Authentication Failures):** Aunque se exige que las claves de API (reader y admin) tengan al menos 16 caracteres y sean distintas, estas claves estáticas se gestionan como variables de entorno y no se evidencia un sistema de rotación dinámica.

2. Calidad de las Mitigaciones Implementadas

- **Qué falta:**
 - Un mecanismo de rate limiting distribuido (por ejemplo, utilizando Redis) para reemplazar el limitador en memoria actual y asegurar la protección en entornos escalados.
 - Una capa de validación semántica robusta (como un LLM-as-a-judge o vector databases para guardrails) para la variable `question` en `AskRequest`, ya que la validación actual `normalize_question` mediante regex es insuficiente.
- **Qué está bien implementado (Qué sobra o destaca):**
 - Destaca positivamente el uso de `compare_digest` del módulo `secrets` en la validación de las API keys en la clase `Settings`, mitigando ataques de sincronización (timing attacks).
 - La sanitización de salidas y entradas rechazando caracteres de control no soportados (`Cc`, `Cf`) previene inyecciones de secuencias de escape.
 - Excelente adición de encabezados de seguridad HTTP nativos, particularmente `Cache-Control: no-store` y `X-Content-Type-Options: nosniff`, los cuales previenen fugas de información en el lado del cliente y proxies.
 - Manejo seguro de errores en `register_error_handlers`, devolviendo códigos y mensajes estandarizados sin filtrar trazas de pila (stack traces) al usuario.

3. Riesgos Específicos en Componentes de IA

- **Prompt Injection (Riesgo Alto):** La seguridad del modelo depende de una función de sanitización que solo bloquea un número finito de patrones en inglés y español. Los atacantes pueden utilizar técnicas de inyección de contexto o codificación de caracteres para saltarse el filtro `validate_question`.
- **Data Leakage / Fuga de Datos (Riesgo Bajo/Medio):** Desde la perspectiva de la API, el riesgo de fuga se mitigó adecuadamente a nivel de transporte con encabezados de no caché. Sin embargo, si los documentos PDF procesados por `chunks_from_pdf` contienen Información Personal Identificable (PII), esta información se almacena directamente en texto claro dentro del índice vectorial FAISS y puede ser recuperada por el LLM si es consultada.

4. Evaluación de las Decisiones de Arquitectura

- **Acoplamiento Síncrono:** El endpoint `POST /ask` procesa la petición al servicio RAG de manera completamente síncrona. Dado que se utiliza un modelo LLM y base vectorial, los tiempos de respuesta pueden ser elevados, bloqueando los workers de FastAPI y causando timeouts (HTTP 503) bajo carga concurrente.
- **Privacidad por Diseño:** La decisión de utilizar `OllamaClient` para inferencia con modelos locales como `llama3.2:3b` y `qwen3-embedding:0.6b` es una excelente decisión arquitectónica de seguridad. Garantiza que los datos procesados en los PDFs de OWASP no se envían a APIs de terceros, eliminando el riesgo de exposición de datos corporativos a proveedores externos.

5. Trade-offs Involucrados

- **Seguridad vs. Complejidad (Guardrails):** Se optó por una validación léxica de expresiones regulares en `guardrails.py` que es muy rápida de ejecutar y fácil de implementar, reduciendo la latencia y la complejidad. El trade-off es que se sacrifica la verdadera resiliencia ante inyecciones de prompts complejas que requerirían un modelo clasificador intermedio más pesado.
- **Escalabilidad vs. Costo Operativo (Rate Limiting):** El uso de `InMemoryRateLimiter` mantiene la aplicación autocontenida y reduce los costos operativos al no requerir bases de datos en memoria externas. El trade-off directo es la incapacidad de mantener límites de peticiones consistentes si el backend requiere escalar horizontalmente para soportar más carga.

6. Evidencia de Herramientas Utilizadas (Análisis de Seguridad)

SonarQube

Comando utilizado:

```
Cuenta gratuita en sonarcloud.io. Resumen de analysis de auditoria.
```

Captura de pantalla (Resultados/Dashboard):

Bloodclot24 / Diplo-2026-DevSecOps-David-IA / Summary

Summary

main

Public

• 3.2k Lines of Code

• Last analysis 1 hour ago

3 analysis warnings

• A bdc72dcc

View on

To prevent false failures on small changes, duplication and coverage checks were ignored because new code has fewer than 20 lines. [Learn more how to adjust this setting.](#)

Quality gate: [Sonar way](#)

Not computed

The next analysis will update the quality gate status.

Security

3 Open issues

C

Reliability

3 Open issues

D

Maintainability

1 Open issues

A

Accepted Issues

0

Valid issues that were not fixed

Coverage

A few extra steps are needed for SonarQube Cloud to analyze your code coverage.
[Set up coverage analysis](#)

Duplications

49.0%

No conditions set on 3.9k Lines

Security Hotspots Deprecated

0

Bloodclot24 / Diplo-2026-DevSecOps-David-IA / Issues

Issues

main

3 analysis warnings

Filters

Software quality

Security3

Reliability3

Maintainability1

Severity

Blocker0

High1

Medium5

Low0

Info0

Code attribute

Status

Security Category

Software quality

Security3

Reliability3

Maintainability1

Severity

Blocker0

High1

Medium5

Low0

Info0

Code attribute

Status

Security Category

Creation Date

Language

Select issues for bulk actions

Change6 issues3h 9min effort

.github/workflows/ci.yml

Using dependencies without locking resolved versions is security-sensitive.

Intentionality

No tags

SecurityMedium

OpenNot assigned

L351h effort1 day ago

Dockerfile

Omitting "--only-binary :all:" can lead to the execution of setup scripts. Make sure it is safe here.

Responsibility

cwe

SecurityMedium

OpenNot assigned

L121h effort1 day ago

Using dependencies without locking resolved versions is security-sensitive.

Intentionality

No tags

SecurityMedium

OpenNot assigned

L121h effort1 day ago

OpenNot assignedL121h effort1 day ago

data/documents/reports/zap-report-final.html

Add "lang" and/or "xml:lang" attributes to the "<html>" or "<body>" element

Intentionality

accessibilitywcag2-a

ReliabilityMedium

OpenNot assigned

L22min effort20 hours ago

data/documents/reports/zap-report-initial.html

Add "lang" and/or "xml:lang" attributes to the "<html>" or "<body>" element

Intentionality

accessibilitywcag2-a

ReliabilityMedium

OpenNot assigned

L22min effort20 hours ago

Duplicate id "10049" found. First occurrence was on line 970.

Intentionality

accessibilityhtml

ReliabilityHighMaintainabilityHigh

OpenNot assigned

L11375min effort20 hours ago

6 of 6 shown

© 2018-2026 SonarSource Sàrl. All rights reserved.

TermsPricingPrivacyCookie PolicySecurityCommunityDocumentationContact usStatusAbout

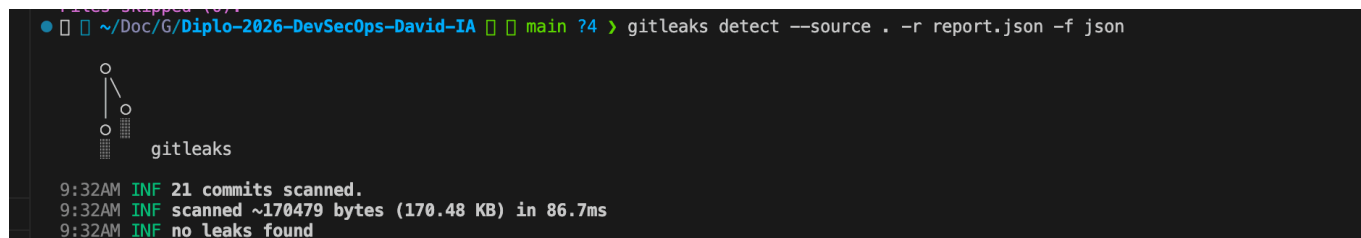
Gitleaks

Comando utilizado:

```
gitleaks detect --source . -r report.json -f json
```

Captura de pantalla (Secretos detectados o reporte limpio):

4 / 9

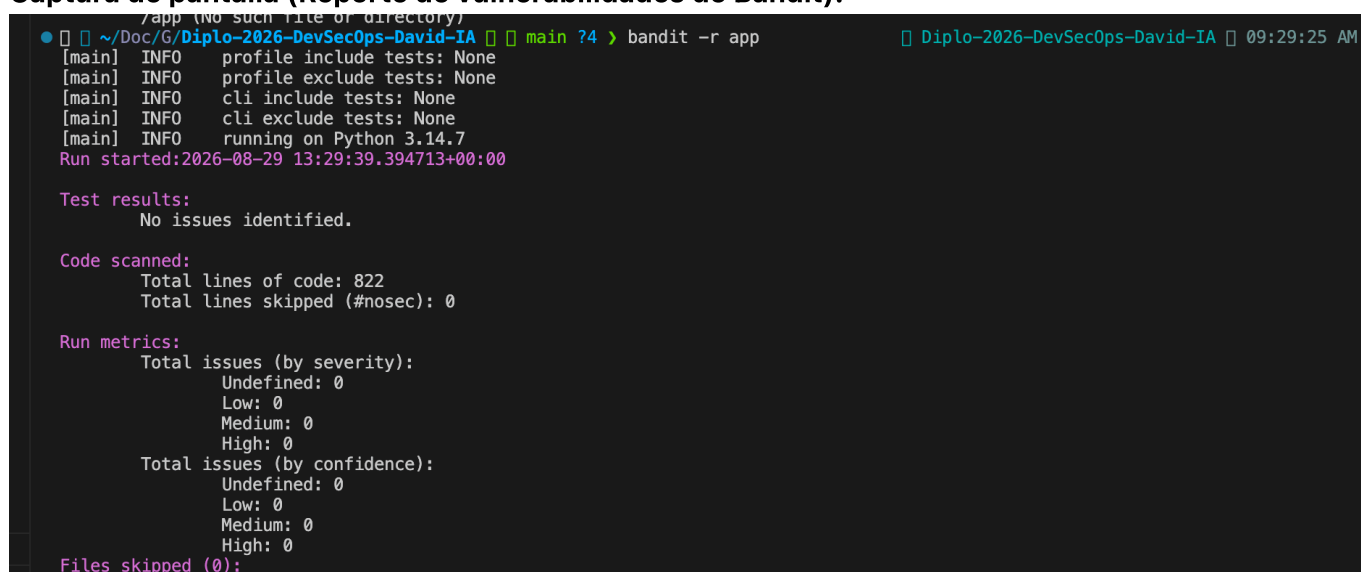


Bandit

Comando utilizado:

```
bandit -r app
```

Captura de pantalla (Reporte de vulnerabilidades de Bandit):

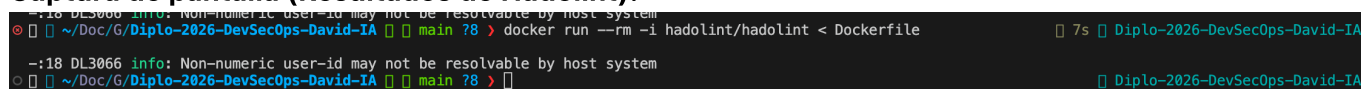


Hadolint

Comando utilizado:

```
docker run --rm -i hadolint/hadolint < Dockerfile
```

Captura de pantalla (Resultados de Hadolint):



Trivy

Comando utilizado:

```
trivy image --format template --template
"@/opt/homebrew/share/trivy/templates/html.tpl" --output report.html diplo-
2026-devsecops-david-ia-api:latest

trivy image --format template --template
"@/opt/homebrew/share/trivy/templates/html.tpl" --output report-ingest.html
diplo-2026-devsecops-david-ia-ingest:latest
```

Captura de pantalla (Tabla de vulnerabilidades críticas/altas):

**diplo-2026-devsecops-david-ia-api:latest (debian 13.6) - Trivy Report - 2026-08-29 09:40:00.061427 -0400 EDT
m=+0.319021292**

debian					
Package	Vulnerability ID	Severity	Installed Version	Fixed Version	Links
apt	CVE-2011-3374	LOW	3.0.3		https://access.redhat.com/security/cve/cve-2011-3374 https://bugs.debian.org/cgi-bin/bugreport.cgi?bug=642480 https://people.canonical.com/~ubuntu-security/cve/2011/CVE-2011-3374.html Toggle more links
bash	TEMP-0841856-B18BAF	LOW	5.2.37-2+b9		
bsdutils	CVE-2026-3184	MEDIUM	1:2.41.5-0+deb13u1		https://access.redhat.com/errata/RHSA-2026-7180 https://access.redhat.com/security/cve/CVE-2026-3184 https://bugzilla.redhat.com/show_bug.cgi?id=2442570 Toggle more links
bsdutils	CVE-2022-0563	LOW	1:2.41.5-0+deb13u1		http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-0563 https://access.redhat.com/security/cve/CVE-2022-0563 https://blog.trailofbits.com/2023/02/16/suid-logic-bug-linux-readline/ Toggle more links
coreutils	CVE-2017-18018	LOW	9.7-3		http://lists.gnu.org/archive/html/coreutils/2017-12/msg00045.html https://access.redhat.com/security/cve/CVE-2017-18018 https://nvd.nist.gov/vuln/detail/CVE-2017-18018 Toggle more links
coreutils	CVE-2025-5278	LOW	9.7-3		http://www.openwall.com/lists/oss-security/2025/05/27/2 http://www.openwall.com/lists/oss-security/2025/05/29/1 http://www.openwall.com/lists/oss-security/2025/05/29/2 Toggle more links
coreutils	CVE-2026-56391	LOW	9.7-3		https://access.redhat.com/security/cve/CVE-2026-56391 https://cert.pl/en/posts/2026/07/CVE-2026-56391 https://git.savannah.gnu.org/cgi/coreutils.git Toggle more links
coreutils	CVE-2026-56392	LOW	9.7-3		https://access.redhat.com/security/cve/CVE-2026-56392 https://cert.pl/en/posts/2026/07/CVE-2026-56391 https://git.savannah.gnu.org/cgi/coreutils.git Toggle more links
diffutils	CVE-2026-53910	LOW	1:3.10-4		https://access.redhat.com/security/cve/CVE-2026-53910 https://cert.pl/en/posts/2026/07/CVE-2026-53910 https://cgit.gil.savannah.gnu.org/cgi/diffutils.git/commit/?id=73ed7ce85cc78effb94daf028c9af6b4e5252e50 Toggle more links
gzip	CVE-2026-41992	HIGH	1.13-1		http://www.openwall.com/lists/oss-security/2026/08/23/1 http://www.openwall.com/lists/oss-security/2026/08/25/1 http://www.openwall.com/lists/oss-security/2026/08/27/2
openssl-provider-legacy	CVE-2026-75803	LOW	3.5.6-1~deb13u2	3.5.7-1~deb13u2	https://github.com/openssl/openssl/commit/119a023330367130307110b9326914e41804026 https://github.com/openssl/openssl/commit/3621237986e27e540bf96a11570929a6e5a9e05b https://github.com/openssl/openssl/commit/6c7aa6f8f6449b71e0137ee8be65fcd239bd7d6a Toggle more links
passwd	CVE-2007-5686	LOW	1:4.17.4-2		http://secunia.com/advisories/27215 http://www.securityfocus.com/archive/1/482129/100/100/threaded http://www.securityfocus.com/archive/1/482857/100/0/threaded Toggle more links
passwd	CVE-2024-56433	LOW	1:4.17.4-2		https://access.redhat.com/errata/RHSA-2025-20559 https://access.redhat.com/security/cve/CVE-2024-56433 https://bugzilla.redhat.com/2334165 Toggle more links
passwd	TEMP-0628843-DBAD28	LOW	1:4.17.4-2		
perl-base	CVE-2026-13221	CRITICAL	5.40.1-6		http://www.openwall.com/lists/oss-security/2026/07/13/5 https://access.redhat.com/security/cve/CVE-2026-13221 https://github.com/Perl/perl5/commit/03f74bbdb3a68350d926ee93d56ee4808c28c4c7.patch Toggle more links
perl-base	CVE-2026-42496	CRITICAL	5.40.1-6		https://access.redhat.com/errata/RHSA-2026-30851 https://access.redhat.com/errata/RHSA-2026-30852 https://access.redhat.com/errata/RHSA-2026-30856 Toggle more links
perl-base	CVE-2026-8376	CRITICAL	5.40.1-6		http://www.openwall.com/lists/oss-security/2026/05/26/1 https://access.redhat.com/security/cve/CVE-2026-8376 https://github.com/Perl/perl5/commit/5e7f119eb2bb1181be908701f22bf7068e722f1c.patch Toggle more links
perl-base	CVE-2026-42497	HIGH	5.40.1-6		https://access.redhat.com/security/cve/CVE-2026-42497 https://github.com/jib/archive-lar-new/commit/17c873492a05eddcd0e18c1485e0b2cccd5a9158.patch https://lists.security.melacpan.org/cve-announce/msg/40396457/ Toggle more links
perl-base	CVE-2026-48962	HIGH	5.40.1-6		http://www.openwall.com/lists/oss-security/2026/05/27/4 https://access.redhat.com/errata/RHSA-2026-29182 https://access.redhat.com/errata/RHSA-2026-29210 Toggle more links
perl-base	CVE-2026-57432	HIGH	5.40.1-6		http://www.openwall.com/lists/oss-security/2026/07/13/6 https://access.redhat.com/security/cve/CVE-2026-57432 https://github.com/Perl/perl5/commit/40754edc72dd3e513d758153c0e2f0215897740e.patch Toggle more links
perl-base	CVE-2026-57433	HIGH	5.40.1-6		http://www.openwall.com/lists/oss-security/2026/07/13/7 https://access.redhat.com/security/cve/CVE-2026-57433 https://github.com/Perl/perl5/commit/e4f681784bcdea91f02a2fa4cdcae5c46779d7.patch Toggle more links
perl-base	CVE-2026-9538	HIGH	5.40.1-6		http://www.openwall.com/lists/oss-security/2026/05/26/4 https://access.redhat.com/errata/RHSA-2026-49525 https://access.redhat.com/security/cve/CVE-2026-9538 Toggle more links

Resumen Ejecutivo de Vulnerabilidades - Trivy Scan

Este reporte resume los hallazgos principales de los escaneos de seguridad de contenedores para las imágenes `diplo-2026-devsecops-david-ia-api` e `diplo-2026-devsecops-david-ia-ingest` (basados en Debian 13.6).

Se ha priorizado la enumeración de las vulnerabilidades **CRITICAL** y **HIGH** debido a su impacto directo en la infraestructura y las operaciones.

Vulnerabilidades Prioritarias (CRITICAL & HIGH)

Nivel de Riesgo	ID de Vulnerabilidad (CVE)	Paquete Afectado	Versión Actual	Versión Corregida (Parche)
CRITICAL	CVE-2026-13221	perl-base	5.40.1-6	-
CRITICAL	CVE-2026-42496	perl-base	5.40.1-6	-
CRITICAL	CVE-2026-8376	perl-base	5.40.1-6	-
HIGH	CVE-2026-14456	openssl (y dependencias)*	3.5.6-1~deb13u2	3.5.7-1~deb13u2
HIGH	CVE-2025-69720	ncurses (y librerías base)**	6.5+20250216-2	-
HIGH	CVE-2026-11822 / 2026-11824	libsqlite3-0	3.46.1-7+deb13u1	-
HIGH	CVE-2026-41992	gzip	1.13-1	-
HIGH	CVE-2026-54369	libacl1	2.3.2-2+b1	-
HIGH	Múltiples CVEs	perl-base	5.40.1-6	-

* Afecta también a `libssl3t64` y `openssl-provider-legacy`. ** Afecta a `libncursesw6`, `libtinfo6`, `ncurses-base`, `ncurses-bin`.

Análisis de Nivel Medio y Bajo (MEDIUM & LOW)

Las imágenes contienen un volumen significativo de hallazgos de menor criticidad (MEDIUM, LOW, UNKNOWN). Las superficies más afectadas incluyen:

- **MEDIUM:** Vulnerabilidades detectadas en el gestor de paquetes Python `pip` (requieren actualización a `26.1.2`), y en utilidades core del sistema como `libc6`, `libc-bin`, `tar` y `systemd`.
- **LOW:** Hallazgos en herramientas de sistema base como `bash`, `coreutils`, `apt`, `mount` y `login.defs`.

Recomendaciones de Remediación

1. **Parchear OpenSSL Inmediatamente:** Es imperativo actualizar el stack de `openssl` a la versión `3.5.7-1~deb13u2`. Es la única vulnerabilidad de severidad alta que cuenta con un parche

definitivo disponible para mitigar la superficie de ataque en la capa de red/criptografía.

2. **Mitigación de la superficie de Perl:** Dado que `perl-base` introduce 3 vulnerabilidades críticas (CRITICAL) y múltiples altas (HIGH) sin parche oficial provisto en el reporte al momento del escaneo, resulta crucial evaluar si las librerías de Perl son un requerimiento estricto para la ejecución de la API y el proceso de ingesta. De no serlo, considere desinstalar el paquete o migrar a una imagen base minimalista (como *distroless* o *alpine*) para reducir la exposición.
3. **Actualización de dependencias de Python:** Escalar la versión de `pip` en la etapa de build a `26.1.2` para limpiar el ruido generado por los CVEs de severidad media (CVE-2025-8869, CVE-2026-3219, CVE-2026-8643).

OWASP ZAP (Zed Attack Proxy)

Comando utilizado o metodología:

```
docker run --rm -v $(pwd):/zap/wrk/:rw --network="host" -t zaproxy/zap-stable zap-full-scan.py -t http://localhost:8000 -r owasp-report.html
```

Captura de pantalla (Alertas levantadas por ZAP):



Sites: <https://localhost:8000> <http://localhost:8000>

Generated on Sat, 29 Aug 2026 13:45:52

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	1
Low	0
Informational	1
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	4
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://localhost:8000	Percentage of responses with status code 4xx	100 %
Info	Informational	http://localhost:8000	Percentage of endpoints with content type application/json	100 %
Info	Informational	http://localhost:8000	Percentage of endpoints with method GET	100 %
Info	Informational	http://localhost:8000	Count of total endpoints	3
Info	Informational	https://localhost:8000	Percentage of endpoints with method GET	100 %
Info	Informational	https://localhost:8000	Count of total endpoints	1

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
HTTP Only Site	Medium	1
Non-Storable Content	Informational	4

Alert Detail

Medium	HTTP Only Site
Description	The site is only served under HTTP and not HTTPS.
URL	http://localhost:8000/
Node Name	https://localhost:8000/
Method	GET
Parameter	
Attack	
Evidence	
Other Info	Failed to connect. ZAP attempted to connect via: https://localhost:8000/
Instances	1
Solution	Configure your web or application server to use SSL (https).
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html https://letsencrypt.org/
CWE Id	311
WASC Id	4
Plugin Id	.10106

Informational	Non-Storable Content
Description	The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.
URL	http://localhost:8000
Node Name	http://localhost:8000
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://localhost:8000/